

UNIT -1

What Is a Vulnerability?

- **Vulnerabilities – The Bedrock of Security**
- A **vulnerability** is a **weakness** in a system, network, application, or configuration.
- Attackers exploit vulnerabilities to:
 - Gain unauthorized access
 - Escalate privileges
 - Steal data
 - Disrupt services
- Vulnerabilities exist because:
 - Software is written by humans
 - Systems are complex
 - Security is often misconfigured or ignored
- Ethical hacking is the process of **finding vulnerabilities before attackers do**.

Why Vulnerabilities Matter to Ethical Hackers

Vulnerabilities in Real-World Security

- Security professionals **assume** you already understand vulnerabilities
- Ethical hackers and penetration testers must:
 - Identify weaknesses
 - Demonstrate impact
 - Recommend fixes
- Just because a vulnerability exists:
 - Does **not always** mean high risk
 - Risk depends on **exploitability and likelihood**

Important Concept:

Vulnerability $\neq$ Risk

Risk = Vulnerability + Likelihood + Impact

Common Types of Vulnerabilities

Major Vulnerability Categories

- **Misconfiguration**
Incorrect service, firewall, or application settings
- **Default Installations**
Default settings, paths, or credentials left unchanged
- **Missing Patches**
Systems not updated despite patches being available
- **Buffer Overflows**
Poor coding allows attackers to overwrite memory
- **Design Flaws**
Logical flaws in encryption, authentication, validation
- **Operating System Flaws**
OS-specific vulnerabilities (Windows, Linux, etc.)
- **Application Flaws**
Bugs or insecure coding in applications
- **Open Services**
Unused but active services exposing attack surface
- **Default Passwords**
One of the most exploited real-world weaknesses

Vulnerability Assessment, Risk & Management -Understanding Risk and Prioritization

Understanding Risk and Prioritization

- Vulnerabilities are **always present**
- Not all vulnerabilities are equally dangerous
- Security teams use:
 - **CVSS (Common Vulnerability Scoring System)**
 - Scores vulnerabilities as Low / Medium / High / Critical
 - **NVD (National Vulnerability Database)**
 - Central repository of known vulnerabilities
- Pen testers must:
 - Stay updated on new vulnerabilities
 - Assess exploitability
 - Understand existing security controls

Final Takeaway:

The goal is not to eliminate all vulnerabilities,
but to **reduce risk to an acceptable level** through proper controls.

Security Basics – The Foundation

- Security is built on a **clear understanding of basic concepts**
- Many security failures occur not because of missing tools, but because:
 - Fundamentals are misunderstood
 - Security is treated as an afterthought
- Organizations often prioritize:
 - Usability
 - Business speedover long-term security

Core Idea

- Security, functionality, and usability exist in **constant balance**
 - Increasing one often reduces the others
- Security decisions are not only technical—they are also business decisions.

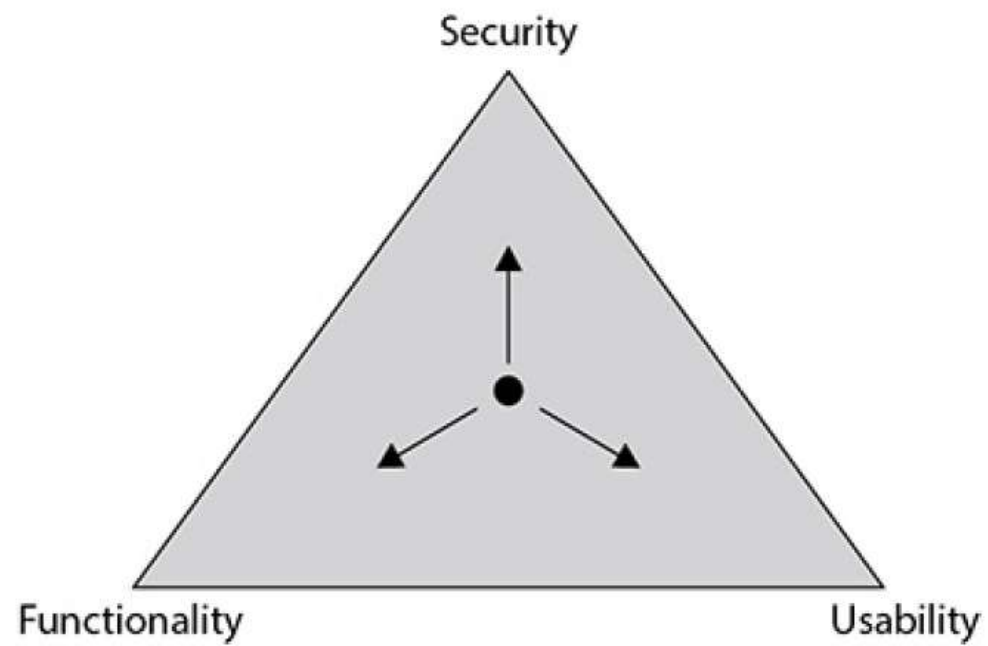


Figure 1-5 The Security, Functionality, and Usability triangle

Threats, Vulnerabilities & Attacks (Attacker's View)

How Attacks Begin

- An attacker first looks for a **target of value**
- The attacker then searches for:
 - Weaknesses
 - Software flaws
 - Design or logic errors
- Attacks are carried out using:
 - **Attack vectors** – paths used to reach the target
 - **Exploits** – techniques or code that take advantage of weaknesses
 - **Payloads** – what the attacker delivers after access

Common Security Terms

- **Zero-day** – a vulnerability unknown to the vendor
 - **Obfuscation** – hiding malicious intent
 - **Bot / Botnet** – compromised systems under remote control
 - **PII** – personally identifiable information
 - **Doxing** – public exposure of private information
- Attacks are researched, planned, and intentional—not random.

Incident Response & Threat Modeling

Threat Modeling

Threat modeling is a structured way to think about security and includes:

1. Identifying security objectives
2. Understanding the application or system
3. Breaking the system into components
4. Identifying possible threats
5. Identifying vulnerabilities

Incident Response Process

When a security incident occurs, organizations follow a sequence:

- Detect and analyze the issue
- Notify relevant stakeholders
- Contain the damage
- Remove malicious access
- Recover affected systems or data
- Document lessons learned

Classroom Message:

Security is not only about prevention—it is also about response and recovery.

Risk Management & Security Controls

Risk Management Process

Risk management involves:

- Identifying risks
- Assessing their impact and likelihood
- Deciding how to handle them
- Monitoring and reviewing over time

Types of Security Controls

- Physical controls** – locks, guards, cameras
- Technical controls** – encryption, access control lists, authentication
- Administrative controls** – policies, training, awareness programs

Control Functions

- Preventive** – stop incidents before they happen
- Detective** – identify incidents in progress or after occurrence
- Corrective** – reduce damage and restore systems

Strong security comes from combining multiple controls, not relying on one.

Business Continuity, Risk Metrics & User Behavior

Business Preparedness

Organizations prepare for disruptions using:

- **Business Impact Analysis (BIA)** – identifying critical systems
- **Maximum Tolerable Downtime (MTD)** – how long systems can be unavailable
- **Business Continuity Plan (BCP)** – keeping operations running
- **Disaster Recovery Plan (DRP)** – restoring systems and data

Understanding Risk in Numbers

• Risk calculations help organizations:

- Prioritize resources
- Plan budgets
- Make informed decisions

User Behavior Awareness

- Users are often the weakest link in security
- Monitoring and understanding user behavior helps identify:
 - Insider threats
 - Abnormal activities
 - Fraud or misuse

Security is a combination of people, processes, and technology

CIA Triad: Foundation of Information Security

CIA Triad – The Core of Security

- The **CIA Triad** stands for:

- Confidentiality**
- Integrity**
- Availability**

- These three principles represent the **primary goals of information security**

- Every security control, policy, and mechanism supports **one or more** of these

- A failure in **any one** of the three can result in a security incident

Key Idea

- Security is not about a single solution

- It is about maintaining the **right balance** between confidentiality, integrity, and availability

If one part of CIA fails, overall security fails.

Confidentiality: Protecting Secrecy & Privacy

What is Confidentiality?

- Ensures information is:
 - Accessible **only to authorized users**
 - Protected from unauthorized disclosure
- Applies to:
 - Individuals (privacy, identity, finances)
 - Organizations (business data, government data)

Common Confidentiality Controls

- Authentication using:
 - User ID and password
 - Biometrics
 - Smart cards
- Access control mechanisms

Common Confidentiality Attacks

- Password attacks
- Credential theft
- Impersonation
- Social engineering

Confidentiality is about **who is allowed to see the data**.

Integrity: Protecting Accuracy & Trust

What is Integrity?

- Ensures data is:
 - Accurate
 - Complete
 - Not altered without authorization
- Applies to data:
 - At rest
 - In transit

Examples of Integrity Failure

- Data modified during transmission
- Unauthorized changes to files or messages
- Manipulated transactions causing financial or reputational damage

How Integrity Is Maintained

- Hash functions (e.g., MD5, SHA)
- Message verification
- Detection of even small changes in data

Integrity Attacks

- Data tampering
- Bit manipulation
- Message alteration

Integrity ensures **data remains trustworthy** from sender to receiver.

Availability: Ensuring Access When Needed

What is Availability?

- Ensures systems, services, and data are:
 - Accessible
 - Operational
 - Available to authorized users when required

Availability Controls

- Redundancy
- Backups
- Failover mechanisms
- Monitoring and maintenance

Availability Attacks

- Denial-of-Service (DoS)
- Resource exhaustion
- Service disruption
- Physical disruptions (power loss, cable removal)

Simple but Important Truth

- Availability attacks do not need to be complex
- Even small actions can disrupt access

Availability ensures **systems are usable when they are needed most.**

Security Policies: Purpose & Importance

What Is a Security Policy?

- A **security policy** is a formal document that defines:
 - How an organization protects its information and systems
 - What security controls are implemented
 - What behavior is expected from users
- It represents **what the organization believes is the best way to secure its resources**
- When implemented correctly, security policies form the **foundation of a strong security program**

Why Security Policies Matter

- Provide clear rules and expectations
 - Support consistent security decisions
 - Help reduce risk and legal liability
 - Guide users, administrators, and partners
- Technology enforces security, but policy defines security.

Common Types of Security Policies

Widely Used Security Policies

- **Access Control Policy**

Defines which resources need protection and who can access them

- **Information Security Policy / Acceptable Use Policy**

Explains how company systems can and cannot be used

- **Information Protection Policy**

Classifies data sensitivity and defines how data is stored, shared, and destroyed

- **Password Policy**

Defines password length, complexity, aging, and reuse rules

- **E-mail Policy**

Governs proper and secure use of organizational email

- **Information Audit Policy**

Defines how, when, and by whom security audits are conducted

Other Common Policies

- Remote Access Policy

- User Account Policy

- Firewall Management Policy

- Network Connection Policy

Most policies are self-explanatory if you understand their purpose.

Policy Strictness: How Restrictive Is Security?

Levels of Policy Strictness

•Promiscuous Policy

- Very open
- Minimal restrictions
- High usability, low security

•Permissive Policy

- Blocks only known dangerous activities
- Allows most services by default

•Prudent Policy

- Balances security and business needs
- Allows some risky services when required

•Paranoid Policy

- Highly restrictive
- Everything denied unless explicitly allowed
- Maximum security, low usability

Key Reality

- No single policy type fits every organization
- Policies must balance:
 - Security
 - Business requirements
 - User productivity

The best security policy is one that users can follow and the business can support.

Common Hacking-Related Terms

Script Kiddie

- An unskilled individual who:
 - Uses pre-written scripts or tools
 - Does not understand how the attack works internally
- Typically targets:
 - Poorly secured systems
 - Outdated vulnerabilities
- High noise, low sophistication

Phreaker

- Specializes in **telecommunication systems**
- Manipulates phone networks to:
 - Make free calls
 - Exploit signaling systems
- Originated before modern internet hacking

Cracker

- Term often used for **malicious hackers**
- Focused on:
 - Breaking security
 - Stealing data
 - Destroying systems

Hacker Classification: The Hat System

What Is the Hat System?

- A traditional way to classify hackers based on:
 - **Intent**
 - **Authorization**
 - **Ethical standing**
- Three primary categories:
 - White Hat
 - Black Hat
 - Gray Hat

White Hat Hackers (Ethical Hackers)

- **Who Are White Hats?**
- Authorized security professionals
- Hired by organizations to:
 - Test security defenses
 - Identify vulnerabilities
 - Improve systems
- **Key Characteristics**
- Always work with:
 - Written permission
 - Defined scope
- Follow:
 - Legal guidelines
 - Professional ethics
- Often called:
 - Security Analysts
 - Penetration Testers
- **Typical Activities**
- Vulnerability assessment
- Penetration testing

Black Hat Hackers (Malicious Hackers)

- **Who Are Black Hats?**
- Illegal hackers acting for:
 - Personal gain
 - Revenge
 - Malicious intent
- **Primary Objectives**
- Steal data (financial, personal, intellectual)
- Destroy or alter information
- Deny service (DoS/DDoS attacks)
- Install malware or ransomware
- **Key Traits**
- No authorization
- No ethical boundaries
- Often operate anonymously
- **Examples of Black Hat Activities**
- Data breaches
- Identity theft
- Financial fraud
- Website defacement

Gray Hat Hackers (The Legal Danger Zone)

- **Who Are Gray Hats?**
- Fall between White and Black hats
- Two main subtypes:
 - Curious learners testing systems without permission
 - “Well-meaning” hackers exposing flaws without consent
- **Key Risk**
- Even good intentions **do not make hacking legal**
- Unauthorized access = crime
- **Real-World Reality**
- Some gray hats get jobs after disclosure
- Many others go to jail for the same act
- **Critical Warning**
- Victims see **only the damage**, not intentions

Advanced Hacker Types

- **Hacktivists**
- Hackers driven by:
 - Political
 - Social
 - Ideological causes
- Common actions:
 - Website defacement
 - Data leaks
 - Service disruption
- Usually illegal activities

- **Suicide Hackers**
- Extremely dangerous category
- Characteristics:
 - Willing to risk jail or life
 - No concern for consequences
- Often cause large-scale damage

Overview of Attack Types

- **What Are Attack Types?**
- Attack types describe **where and how** a hacker targets a system.
- They help security professionals:
 - Identify weak points
 - Apply correct defensive controls
 - Understand attacker mindset
- **Four Major Attack Categories**
 1. Operating System (OS) Attacks
 2. Application-Level Attacks
 3. Shrink-Wrap Code Attacks
 4. Misconfiguration Attacks

Operating System (OS) Attacks

- **What Are OS Attacks?**
 - Attacks that target **weaknesses in the operating system itself**
 - Commonly exploit:
 - Default settings
 - Old vulnerabilities
 - Poor initial installation practices
- **Why OS Attacks Are Common**
 - Many users:
 - Accept default installation options
 - Forget to harden the OS
 - Delay security updates and patches
- **Examples of OS Vulnerabilities**
 - Administrator account with no or weak password
 - Guest account enabled
 - All ports left open by default
 - Unpatched OS vulnerabilities
- **Real-World Example**
 - A newly installed Windows/Linux server is deployed without updates.
 - Attacker exploits a known vulnerability that already has a public exploit.

Application-Level Attacks

- **What Are Application-Level Attacks?**
- Attacks targeting:
 - Application logic
 - Source code flaws
 - Input handling errors
- **Why Applications Are a Gold Mine**
- Organizations often secure:
 - OS
 - Network
- But **ignore application security**
- Many applications are released without:
 - Security testing
 - Code reviews
 - Penetration testing
- **Common Application Vulnerabilities**
- SQL Injection
- Cross-Site Scripting (XSS)
- Broken authentication
- Improper input validation
- **Real-World Example**
- A login form does not validate user input.
- Attacker injects SQL commands to bypass authentication.

Shrink-Wrap Code & Misconfiguration Attacks

- **Shrink-Wrap Code Attacks**
- Exploit **built-in scripts and code** that come with off-the-shelf software
- Purpose of such code:
 - Easy installation
 - Easy administration
- Problem:
 - These scripts often remain enabled and unsecured
- **Examples**
- Default admin pages
- Sample scripts
- Setup files left accessible
- Default credentials

Misconfiguration Attacks

- Exploit systems that are **incorrectly configured**
- Often done intentionally for ease of use
- **Typical Causes**
 - All firewall ports opened
 - Unnecessary services enabled
 - Weak security policies
 - Lowest security settings applied
- **Real-World Example**
 - Admin disables firewall rules to avoid user complaints.
 - Attacker scans and accesses open services

Hacking Phases: Why a Structured Approach Matters

- **Key Idea**
- Hacking is **not random guessing**
- Both ethical hackers and criminals follow **structured steps**
- Skill comes from **process + practice**, not shortcuts
- **Pilot Analogy (Very Important)**
- Pilots don't rely on "feel" alone
- They follow:
 - Procedures
 - Checklists
 - Training
- Same applies to hacking:
 - Discipline first
 - Intuition later
- **Why EC-Council Teaches Phases**
- To standardize how attacks are understood
- To help:
 - Ethical hackers plan tests
 - Defenders predict attacker behavior

Overview of the 5 Hacking Phases

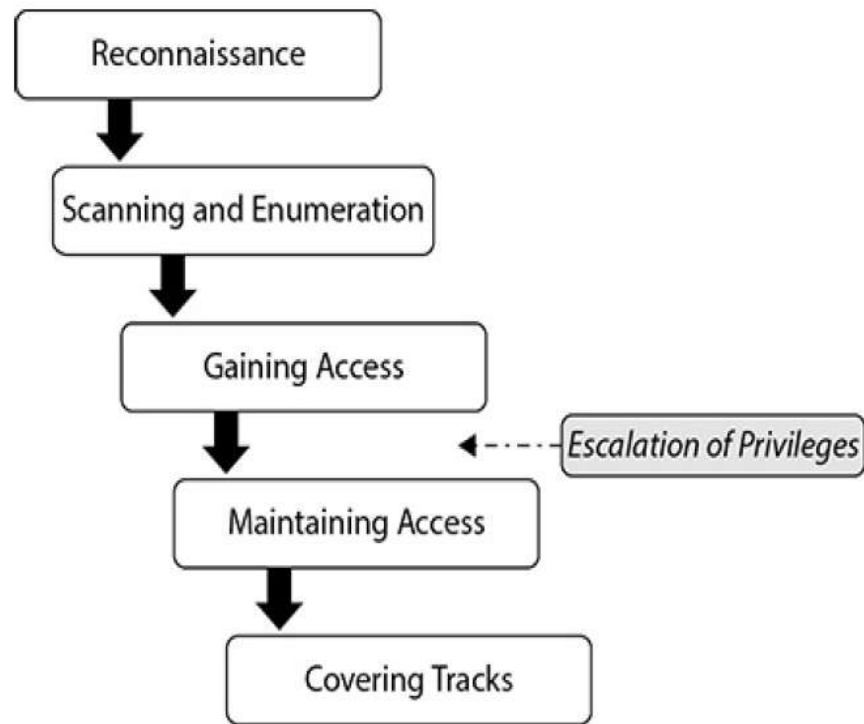


Figure 1-7 Phases of ethical hacking

Phase 1: Reconnaissance (Information Gathering)

Purpose

- Learn everything possible about the target
- Without attacking systems yet

What Reconnaissance Answers

- Who is the target?
- What systems exist?
- Where are they located?
- How does the organization operate?

Nature of Recon

- Focused on **information**, not exploitation
- Builds a **target profile**

Reconnaissance Types: Passive vs Active

Passive Reconnaissance

- No direct interaction with target systems
- No packets sent to target
- Very low detection risk

Examples

- Google searches
- Social media
- Job postings
- Observing physical security

Reconnaissance Types: Passive vs Active

Active Reconnaissance

- Direct interaction with target
- Packets or communication involved
- Some detection risk

Examples

- DNS queries
- Social engineering calls
- Network sniffing
- Dumpster diving (exam: passive, real life: risky)

Passive = invisible

Active = interaction present

Phase 2: Scanning & Enumeration

- **Purpose**
- Convert recon data into **technical detail**
- Identify systems that can be attacked
- **What Happens in This Phase**
- Identify:
 - Live hosts
 - Open ports
 - Running services
 - OS types
 - User accounts
- **Key Difference from Recon**
- Recon: *What exists?*
- Scanning: *How is it configured?*
- **Examples**
- Ping sweep
- Port scan
- Network mapping
- Vulnerability scanning

Phase 3: Gaining Access (Exploitation Phase)

- **Purpose**
- Break into systems using identified weaknesses
- **Why This Phase Gets Attention**
- This is where:
 - Controls are bypassed
 - Unauthorized access occurs
- Often misunderstood as “hacking itself”
 - But it’s only **one phase**
- **Common Techniques**
- SQL Injection
- Buffer overflow
- Weak passwords
- Open Wi-Fi exploitation
- Misconfigured services

Phase 4: Maintaining Access

- **Purpose**
- Ensure attacker can return later
- Avoid repeating exploitation
- **Why Attackers Maintain Access**
- Long-term data access
- Launch further attacks
- Use system as a “zombie”
- **Common Methods**
- Backdoors
- Trojans
- Rootkits
- Credential persistence
- Installing sniffers
- “Zombie system” → Maintaining access

Phase 5: Covering Tracks

- **Purpose**
 - Avoid detection
 - Hide evidence of compromise
- **Common Techniques**
 - Modifying logs
 - Hiding files
 - Clearing traces
 - Encrypted or tunneled communication
- **SIEM Awareness**
 - SIEM systems:
 - Collect logs
 - Detect anomalies
 - Alert SOC teams
 - Example: Splunk
- **Critical Ethical Distinction**
 - Ethical hackers:
 - May NOT delete or corrupt logs
 - Must follow “do no harm” clauses

Who Is an Ethical Hacker?

- **The Ethical Question**
 - Hacking looks illegal
 - Tools and techniques are the same
 - So what makes it *ethical*?
- **The Answer**
- **Intent + Authorization + Boundaries**
- Ethical hackers:
 - Think like criminals
 - Act with permission
 - Work to **prevent attacks**
- **Cybersecurity Example**
- Running password attacks:
 - Illegal if unauthorized
 - Ethical if approved in a contract

Authorization, Contracts & Scope (Your Legal Shield)

- **Why Agreements Are Critical**
- Ethical hacking **without written permission** = crime
- Authorization protects:
 - The hacker
 - The organization
- **Key Documents**
- **Contract**
 - Defines permission
 - Often called “get-out-of-jail-free card”
- **NDA (Non-Disclosure Agreement)**
 - Prevents data leaks
- **Scope Definition**
 - What systems can be tested
 - What attacks are allowed
- **Cybersecurity Example**
- Allowed: password testing
- Not allowed: DoS attacks
- Allowed: firewall testing
- Not allowed: production databases

Critical Systems, Trust & the “Sunshine” Effect

The Real-World Dilemma

- Clients often say:
 - “This system is too critical to test”
- But:
 - Untested systems often become **most vulnerable**

Cybersecurity Example

- Legacy payroll server
- No updates for years
- Protected by “compensating controls”
- Never tested because “it might break”

Attackers **love** such systems.

Trust Over Time

- First year: limited testing
- Later years: deeper testing as trust builds
- Security improves progressively

Key Insight

No mold grows where the pen-test light shines.

Final Teaching Message

- Ethical hacking balances:
 - Risk
 - Business impact
 - Security necessity

What Is a Penetration Test & Why Organizations Need It

What Is a Penetration Test (Pen Test)?

- **A formal, authorized security assessment**
- Simulates real-world attacks on:
 - Systems
 - Networks
 - Applications
- Objective: **Identify vulnerabilities before attackers do**

Why Organizations Request Pen Tests

- **Regulatory compliance**
 - Healthcare → HIPAA
 - Finance → SOX, PCI-DSS
- **Security assurance**
 - Verify existing controls
- **Post-breach trust rebuilding**
 - Demonstrate improved security to customers
- **Risk awareness**
 - Understand real impact of vulnerabilities

A pen test proves security — policies alone do not.

Pen Test

Pen Test Characteristics

- Fully authorized
- Clearly documented
- Scoped and controlled
- Designed to measure risk, not cause damage

The Three Phases of a Penetration Test

- **Phase 1: Preparation**
- Contract and authorization finalized
- Scope defined:
 - Systems allowed
 - Attacks permitted
- NDA signed
- Timeline agreed
- **Phase 2: Assessment (Conduct Phase)**
- Actual testing occurs
- Ethical hacker performs:
 - Reconnaissance
 - Scanning
 - Exploitation
- Follows **five hacking phases**
- **Phase 3: Conclusion (Post-Assessment)**
- Detailed report prepared
- Includes:
 - Vulnerabilities found
 - Attack methods used
 - Risk levels
 - Recommendations

Five Hacking Phases Inside a Pen Test

How Pen Test and Hacking Phases Connect

- Pen test = **project**
- Hacking phases = **execution method**
- **Five Hacking Phases**
 1. Reconnaissance
 2. Scanning & Enumeration
 3. Gaining Access
 4. Maintaining Access
 5. Covering Tracks
- **Important Insight**
- Pen testers generally follow these phases
- Real attackers may skip steps
- Ethical hackers follow structure for:
 - Completeness
 - Documentation
 - Defensibility

Pen Test Knowledge Levels: Black, White & Gray Box

- **Allowable Knowledge Models**
 - Pen tests simulate attackers with different knowledge levels.
- **Black-Box Testing**
 - No internal knowledge
 - Simulates external attacker
 - Time-consuming and expensive
 - Focuses on **outside threats only**
- **White-Box Testing**
 - Full system and network knowledge
 - Simulates trusted insider/admin
 - Faster and cheaper
 - Deep visibility
- **Gray-Box Testing**
 - Partial knowledge
 - Simulates internal user
 - Best for testing **privilege escalation**
 - Reflects real-world attack patterns

Why Laws Matter in Ethical Hacking

Ethical Hacking ≠ Legal Immunity

- Ethical hacking involves **activities that can look illegal** if done without authorization
- Your *intention* to help does **not automatically protect you**

Why law is critical in cybersecurity

- You handle:
 - Networks
 - Sensitive data
 - Personal and financial information
- A single mistake can lead to:
 - Legal action
 - Fines
 - Criminal charges

Key message

In cybersecurity, **technical skill without legal awareness is dangerous**

“Ignorance of the Law Is No Excuse”

Foundational legal principle

- Western legal systems follow this rule:

Not knowing a law does NOT exempt you from it

Why this rule exists

- If ignorance were allowed as an excuse:
 - Anyone could escape punishment by claiming “I didn’t know”
- Law assumes:
 - Laws are published
 - Citizens have a duty to know relevant laws

What it means for YOU as an engineer

- You are expected to know laws related to:
 - Networking
 - Data access
 - Privacy
 - Hacking activities

Key Laws & Standards Ethical Hackers Must Know

HIPAA

- Protects medical data
 - Covers:
 - Privacy
 - Security
 - Electronic health records
 - Applies to hospitals, insurers, healthcare IT
-
- **Sarbanes-Oxley (SOX)**
 - Ensures accuracy of corporate financial reporting
 - Prevents fraud and manipulation
 - Includes:
 - Auditing rules
 - Accountability enforcement

Key Laws & Standards Ethical Hackers Must Know

- **PCI-DSS**
- Applies to **payment card data**
Key requirements include:
 - Firewalls
 - No default passwords
 - Encryption
 - Access control
 - Logging and monitoring
 - Security policies

Key Laws & Standards Ethical Hackers Must Know

- **COBIT**
- IT governance framework
- Helps align:
 - Business risks
 - Technical controls
- Four domains:
 - Planning & Organization
 - Acquisition & Implementation
 - Delivery & Support
 - Monitoring & Evaluation

Key Laws & Standards Ethical Hackers Must Know

- **ISO/IEC 27001:2013**
- Information Security Management System (ISMS)
- Focuses on:
 - Legal compliance
 - Risk management
 - Continuous improvement

Reconnaissance: Information Gathering for the Ethical Hacker

Table of Contents

- Define active and passive footprinting
- Identify methods and procedures in information gathering
- Understand the use of social networking, search engines, and Google hacking in information gathering
- Understand the use of whois, ARIN, and nslookup in information gathering
- Describe the DNS record types

Information Gathering – The Lion Hunt Analogy

Why Information Gathering Comes First

- In nature, predators **don't attack immediately**
- They **observe first**, plan later

The Lion Hunt Example

- Lions:
 - Sit quietly
 - Watch herd movement
 - Identify weak targets (young/old)
 - Choose best attack direction
- Actual attack is:
 - Fast
 - Coordinated
 - Efficient

Connection to Ethical Hacking

- Hackers don't start with attacks
- They start with **observation**
- This observation phase is called:
Information Gathering / Footprinting

Most of the real work happens before the attack begins

What is Footprinting in Ethical Hacking?

Footprinting means: Collecting information about a target **before attacking it**

Relationship with Reconnaissance

- Reconnaissance = Broad information gathering
- Footprinting = **High-level mapping** of the target
- Remember: **Footprinting is part of reconnaissance**

Why Footprinting is Critical

- Helps you:
 - Understand the target
 - Reduce guesswork
 - Avoid noisy attacks
- Saves:
 - Time
 - Effort
 - Risk

A hacker who skips footprinting usually fails later

What Kind of Information Are We Looking For?

Technical Information

- Network architecture
- Routers, servers, firewalls
- Public-facing websites & applications
- DNS records
- IP ranges

Non-Technical Information (Very Important)

- Business critical functions
- Sensitive data (customer data)
- Employee behavior & routines
- Physical security measures

Why Employees Matter

- Employees are:
 - Trusted users
 - Often the weakest link
- Social engineering targets come from here

Any information—technical or human—can become an attack path

Passive vs Active Footprinting

Passive Footprinting

- No direct interaction with target systems
- Uses public information
- Examples:
 - Company website
 - Google search
 - DNS lookups
 - Public records
 - Social media
 - Safe
Silent
Preferred first step

Passive vs Active Footprinting

- **Active Footprinting**
- Direct interaction with target systems
- Can trigger alerts
- Examples:
 - Network scans
 - Probing IP addresses
 - Talking to employees (social engineering)
- Risky
Detectable

Goals, Benefits & Strategy of Footprinting

Key Benefits of Footprinting

1. Understand security posture
2. Reduce attack surface
3. Identify vulnerabilities
4. Draw a network map

Footprinting Strategy

- Start with:
 - “50,000-foot view” (web, public data)
- Move gradually to:
 - Technical details (DNS, network)

Avoiding a Common Mistake

- Too little data → blind attack
 - Too much data → confusion
- Focus on **relevant information**, not everything

Good footprinting is focused, silent, and purposeful

What Is Passive Footprinting?

- **What Passive Footprinting IS**
- Gathering **publicly accessible information**
- No direct interaction with target systems
- No modification or probing of resources
- **What Passive Footprinting is NOT**
- It does NOT mean:
 - No effort
 - No tools
 - No investigation

What Is Passive Footprinting?

- Passive footprinting includes:
- Search engines
- Public records
- Social media
- Competitive intelligence
- DNS information
- Website analysis
- Dumpster diving

Competitive Intelligence as Passive Footprinting

- **What Is Competitive Intelligence?**
- Information a company gathers about:
 - Competitors
 - Products
 - Customers
 - Market position
- **Why It Matters in Ethical Hacking**
- Hackers use the **same public information**
- It reveals:
 - Business priorities
 - Critical assets
 - Valuable data targets

Competitive Intelligence as Passive Footprinting

- **Is Competitive Intelligence Legal?**
- Yes
- It is:
 - Legal
 - Expected
 - Widely practiced in business
- **Examples of Competitive Intelligence Sources**
- Company websites
- Financial disclosures
- Press releases
- Market reports
- Website traffic analysis

Passive Footprinting Sources & What They Reveal

- **Company Website (Goldmine of Data)**
- From a company's own site, you can find:
 - Company history
 - Organization structure
 - Employee directories
 - Technologies used
 - Future plans
- Risk:
 - Technical details help attackers
 - Directory info aids social engineering

Business & Financial Databases

- Used to gather:
- Company origins
- Financial health
- Expansion plans
- Examples (conceptual, not tool-based):
- SEC filings
- Business intelligence platforms
- Financial news sites

Online Reputation & Traffic Analysis

- Reveals:
- Public perception
- Brand exposure
- Website popularity
- Why it matters:
- High traffic = attractive target
- Poor reputation = weak defenses

What Is Active Footprinting?

- **Active footprinting** involves:
- Direct interaction with the target organization
- Information gathering that **can be noticed or detected**

Simple Example

- Reading a company website → Passive
- Asking an employee about infrastructure → **Active**

Key Takeaway

Active footprinting exposes your presence to the target

Why Active Footprinting Is Riskier

- You are:
 - Talking to employees
 - Sending messages
 - Interacting with systems
- Humans notice unusual behavior

Real-Life Analogy

- Passive = Watching from a distance
- Active = Walking into the building and asking questions

Example

- DNS lookups → rarely noticed
- Phone call to IT helpdesk → noticed immediately

Key Takeaway

Active footprinting trades stealth for deeper information

Social Engineering as Active Footprinting

What Is Social Engineering?

Social engineering means:

Convincing people to reveal information, often without realizing it

Why It's Powerful

- Humans are often:
 - Helpful
 - Trusting
 - Unaware of security risks

Common Active Social Engineering Methods

- Phone calls (vishing)
- Face-to-face conversations
- Emails asking questions
- Social media direct interaction

People are often the weakest link in security

Active vs Passive Social Media Use

- **Passive Social Media Use**

- Viewing profiles
- Reading posts
- Collecting public information

- **Active Social Media Use**

- Sending messages
- Posting questions
- Commenting to extract info
- Tweeting at employees

Search Engines in Active Footprinting

Why Search Engines Matter

- They reveal:
 - Technical info
 - Employee data
 - Exposed files
 - Infrastructure clues

Common Uses

- Learning tools
- Studying technologies
- Understanding system behavior

Location & Mapping Intelligence

- Satellite images
- Building layouts
- Entry points
- Physical security clues

Search engines are reconnaissance tools, not just browsers

Job Boards – A Hidden Goldmine

Why Job Listings Are Valuable

Job ads often reveal:

- Operating systems
- Databases
- Backup software
- Cloud platforms

Example

A job post says:

“Experience with Windows Server 2019, SQL Server, Veritas Backup”

This reveals:

- OS type
- Database platform
- Backup solution

Why This Matters

- Known software = known vulnerabilities
- Helps attackers plan next steps

Organizations often publish their own weaknesses

Active Footprinting Risks & Legal Concerns

Why Agreements Matter

Even “safe” tools can:

- Delete data
- Overload applications
- Trigger defensive actions

Real-World Scenario

- Web crawler deletes poorly coded data
- Admin shuts down systems
- Business impact occurs

Why You Can Be Liable

- Tools don't care about intent
- Law cares about impact

Authorization and scope protect ethical hackers—not intent

Google Hacking as Active Footprinting

What Is Google Hacking?

Using advanced search operators to:

- Discover exposed files
- Find vulnerable pages
- Locate misconfigured systems

Why It's Powerful

- Search engines index:
 - Config files
 - Logs
 - Backup files
 - Source code

Important Legal Reminder

- Searching is legal
- Exploiting what you find is NOT**

Active footprinting gives deep insight—but demands discipline, scope, and legality

Google Search String Operators

Operator	Syntax Example (CBIT)	What Information It Collects
site	site:cbit.ac.in	Lists all pages indexed under CBIT domain
filetype	site:cbit.ac.in filetype:pdf	Finds PDFs like syllabi, notices, reports
filetype	site:cbit.ac.in filetype:xls	Finds Excel files
intitle	site:cbit.ac.in intitle:login	Finds pages with 'login' in title
allintitle	site:cbit.ac.in allintitle:student login	Narrows search to specific login pages

Google Search String Operators

inurl	<code>site:cbit.ac.in</code> <code>inurl:admin</code>	Finds URLs containing 'admin'
allinurl	<code>site:cbit.ac.in</code> <code>allinurl:student login</code>	Finds URLs with multiple keywords
index of	<code>"intitle:index of"</code> <code>site:cbit.ac.in</code>	Finds open directories (if any)
info	<code>info:cbit.ac.in</code>	Shows what Google knows about the site
link	<code>link:cbit.ac.in</code>	Shows websites linking to CBIT
related	<code>related:cbit.ac.in</code>	Finds similar educational websites

Website & E-mail Footprinting – Introduction

What is Website & E-mail Footprinting?

- A phase of **information gathering (reconnaissance)**
- Focuses on collecting intelligence from:
 - Websites
 - Web applications
 - E-mail communications
- Mostly **passive** in nature
- Requires **technical understanding**, not brute force

Objectives of Website Footprinting

- **Primary Objectives**

- Identify technologies used by the website
- Understand server and OS details
- Discover directory and file structure
- Collect contact and organizational information

- **Why This Matters**

- Helps narrow attack vectors
- Saves time in later phases
- Reduces noise and detection

Website Footprinting Tools – Overview

- **Common Website Footprinting Tools**

- Burp Suite
- Firebug / Browser Developer Tools
- Website Informer

- **Purpose of These Tools**

- Capture HTTP requests and responses
- Analyze headers and cookies
- Identify server and content details

- **What Ethical Hackers Look For**

- Server version info
- Session handling mechanisms
- Scripting and frameworks used

Headers, Cookies & HTML Source Analysis

- **HTTP Headers Reveal**

- Web server software
- Content type (HTML, JSON, XML)
- Connection status
- Cache and security policies

- **Cookies Can Reveal**

- Session identifiers
- Application behavior
- Server-side scripting methods

- **HTML Source Code Analysis**

- Hidden form fields
- Developer comments
- Hardcoded values
- File paths and internal references

Web Mirroring – Concept & Purpose

- **What is Web Mirroring?**

- Copying the entire website to a local system
- Allows offline analysis
- Still considered **footprinting**

- **Why Web Mirroring is Useful**

- Faster inspection
- No repeated access to target
- Easier navigation of directories

- **Questions It Helps Answer**

- What is this directory used for?
- Are there unused or old files?
- How is the site structured internally?

Web Mirroring Tools

- **Popular Web Mirroring Tools**

- HTTrack
- Black Widow
- WebRipper
- Teleport Pro
- GNU Wget
- Backstreet Browser

- **Capabilities of These Tools**

- Download complete website
- Preserve directory structure
- Fetch linked resources (images, scripts)

E-mail Footprinting – Basics

- **What is E-mail Footprinting?**
 - Collecting information through e-mail communication
 - Often underestimated but highly effective
- **Information Obtained from E-mails**
 - IP addresses
 - Mail servers used
 - Physical location clues
 - Time stamps and routing paths
- **Why E-mail Footprinting is Powerful**
 - Reveals internal infrastructure
 - Helps plan social engineering or phishing

E-mail Headers & Tracking Tools

- **E-mail Header Analysis**
- Shows complete path of the e-mail
- Identifies:
 - Sender IP
 - Intermediate servers
 - Mail client and OS details
- **E-mail Tracking**
- Tracks:
 - When an e-mail is opened
 - Where it is opened from
 - User interaction behavior
- **Common E-mail Tracking Tools**
- GetNotify
- ContactMonkey
- Yesware
- Read Notify
- WhoReadMe
- MSGTAG
- Trace Email
- Zendio

DNS Footprinting – Introduction

- **What is DNS Footprinting?**
- DNS Footprinting is the process of **gathering information from the Domain Name System**
- It helps ethical hackers understand:
 - Network structure
 - Server roles
 - Public-facing services
- Considered **passive reconnaissance**

- **Why DNS is Important**
- DNS acts like the **road sign system of the Internet**
- Converts **domain names → IP addresses**
- Without DNS, users would need to remember IP addresses

- **Why Hackers Love DNS**
- DNS records reveal **valuable infrastructure details**
- Often **freely accessible**

DNS Basics – How DNS Works

- **Basic Function of DNS**
- Maps:
 - Domain names → IP addresses
 - IP addresses → domain names
- Makes internet navigation simple and efficient
- **DNS Infrastructure**
- DNS is made up of **servers across the globe**
- Each server manages a **namespace**
- Organized like an **inverted tree structure**
- **Key Point**
- Each DNS server knows:
 - Its own records
 - How to reach the server above it

DNS Namespace & Hierarchical Structure

DNS Hierarchy

- Root level
- Top-Level Domains (TLDs) – .com, .org, .edu
- Domain level – example.com
- Subdomains – mail.example.com

Authoritative DNS Server

- Holds official records for a domain
- Responsible for accurate responses

Why This Matters

- Querying the right server gives **accurate network information**
- Helps attackers map infrastructure

DNS Port Numbers & Protocols

- **Important DNS Ports**

- **Port 53** → DNS traffic

- **Protocols Used**

- **UDP** → Normal DNS queries
- **TCP** → Zone transfers

DNS Records – Information Goldmine

- **Why DNS Records Are Dangerous**
- DNS records describe **network layout**
- Can expose:
 - Servers
 - Email systems
 - Public services
- **Common DNS Record Types**
- **A** – Hostname to IP
- **MX** – Mail servers
- **NS** – Name servers
- **SOA** – Zone authority
- **PTR** – Reverse lookup
- **CNAME** – Alias

SOA Record – The Most Important DNS Record

- **What is an SOA Record?**
 - Start of Authority record
 - Defines who controls the DNS zone
- **Information Contained**
 - Primary DNS server
 - Admin contact email
 - Serial number
 - Refresh, retry, expire times
 - TTL (Time To Live)
- **Why Attackers Care**
 - Reveals:
 - DNS structure
 - Cache timing
 - Update frequency

Zone Transfer – DNS Footprinting Jackpot

- **What is a Zone Transfer?**
- Copying **all DNS records** from a server
- Used for synchronization between DNS servers
- **Why It's Dangerous**
- Exposes **entire network map**
- Reveals:
 - Internal hosts
 - Mail servers
 - Subdomains
- **Security Measure**
- Zone transfers should be **restricted**
- Only allowed between trusted servers

DNS Poisoning – Why DNS Security Matters

- **What is DNS Poisoning?**
 - Altering DNS cache to redirect traffic
 - User unknowingly connects to attacker's server
- **How It Works**
 - Fake DNS entry inserted into cache
 - User receives malicious IP address
- **Mitigation**
 - Reduce cache TTL
 - Use **DNSSEC**
 - Secure DNS servers

WHOIS & Regional Internet Registries (RIRs)

- **What is WHOIS?**
- Tool to query domain registration information
- Provides:
 - Owner details
 - Contact info
 - Name servers
 - IP ranges
- **Major RIRs**
- ARIN – North America
- APNIC – Asia-Pacific
- RIPE – Europe
- LACNIC – Latin America
- AfriNIC – Africa
- **Why WHOIS is Useful**
- Helps identify:
 - Organization details
 - Attack surface
 - Social engineering targets

DNS Footprinting Tools – nslookup & dig

- **nslookup**
 - Command-line DNS query tool
 - Available on almost all OS
 - Supports:
 - Interactive mode
 - Record-specific queries
 - Zone transfer attempts
- **dig (Domain Information Groper)**
 - Advanced DNS query tool
 - Popular in Unix/Linux
 - Provides detailed DNS responses

Network Footprinting – Overview

- Network footprinting is the process of **identifying and defining the IP address range** of a target organization
- Helps determine **where the target network starts and ends**
- Reduces effort in later phases like scanning and enumeration
- Works best when the target owns its IP range
- Becomes complex when services are hosted on **cloud platforms**
- Considered **passive reconnaissance**
- **Cybersecurity Relevance:**
Understanding network boundaries helps attackers and defenders identify the **actual attack surface**

Discovering Network Range Using IP Registries

- Public IP ranges are managed by **Internet Registries**
- Network range can be identified using a known IP address
- Registries provide:
 - IP address block range
 - Organization name
 - Hosting provider details
- Commonly used registry:
 - **ARIN (American Registry for Internet Numbers)**
- **Example:**
- Entering a website IP into ARIN may show:
 - Cloud provider ownership (AWS, Azure, GCP)
 - On-premises infrastructure ownership
- **Security Insight:**
Cloud-hosted IPs indicate **shared responsibility model**

Administrative & Technical POC Information

- IP registry data often includes:
 - Administrative Point of Contact (Admin POC)
 - Technical Point of Contact (Tech POC)
- POC details may include:
 - Names
 - Email addresses
 - Phone numbers
- Useful for:
 - Incident response
 - Network management
- Dangerous when misused for:
 - Social engineering
 - Impersonation attacks
- **Cybersecurity Example:**
Attackers may impersonate a listed technical contact to gain trust and extract sensitive information

Traceroute – Network Path Discovery

- Traceroute maps the **path packets take from source to destination**
- Uses **TTL (Time To Live)** to identify each hop
- Displays:
 - Router IP addresses
 - Hostnames
 - Transit time between hops
- Command names:
 - **tracert** (Windows)
 - **traceroute** (Linux)
- **Security Value:**
Helps identify:
 - Network boundaries
 - Routing devices
 - Potential firewall locations

Why OSI Model in Ethical Hacking?

- Ethical hacking is not about tools
- Every attack happens at an OSI layer
- OSI tells where to attack

Ethical Hacker's Mindset

- User uses applications
- Admin manages systems
- Hacker breaks communication

What is OSI Model?

- Open Systems Interconnection
- 7-layer reference model
- Explains data flow

Why Layered Architecture?

- Reduces complexity
- Easy debugging
- Each layer is an attack surface

OSI Model as Attack Map

- Each layer has vulnerabilities
- Identify layer to identify attack

OSI 7 Layers

- Application
- Presentation
- Session
- Transport
- Network
- Data Link
- Physical

Physical Layer

- Hardware & signals
- USB attacks
- Hardware keyloggers

Data Link Layer

- MAC addressing
- ARP spoofing
- MITM attacks

Network Layer

- IP addressing
- Routing
- IP spoofing & DoS

Transport Layer

- TCP / UDP
- Ports
- Port scanning (Nmap)

Session Layer

- Session control
- Session hijacking
- Cookie attacks

Presentation Layer

- Encryption & decryption
- SSL stripping
- Weak encryption

Application Layer

- User interaction
- SQL Injection
- XSS, CSRF

Attacks vs OSI Layers

- USB → Physical
- ARP → Data Link
- IP spoof → Network
- SQLi → Application

Tools vs OSI Layers

- Nmap → L3/L4
- Wireshark → L2–L7
- Metasploit → L7

odd-http.pcap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

Apply a display filter ... <Ctrl-/> Expression...

No.	Time	Source	Destination	Protocol	Length	Info
4	0.025749	172.16.0.122	200.121.1.131	TCP	54	[TCP Window Update] [TCP ACKed unseen segment] 80 → 10554 [ACK] Seq=...
5	0.076967	200.121.1.131	172.16.0.122	TCP	1454	[TCP Previous segment not captured] [TCP Spurious Retransmission] 10...
6	0.076978	172.16.0.122	200.121.1.131	TCP	54	[TCP Dup ACK 2#1] [TCP ACKed unseen segment] 80 → 10554 [ACK] Seq=1 ...
7	0.102939	200.121.1.131	172.16.0.122	TCP	1454	[TCP Spurious Retransmission] 10554 → 80 [ACK] Seq=5601 Ack=1 Win=65...
8	0.102946	172.16.0.122	200.121.1.131	TCP	54	[TCP Dup ACK 2#2] [TCP ACKed unseen segment] 80 → 10554 [ACK] Seq=1 ...
9	0.128285	200.121.1.131	172.16.0.122	TCP	1454	[TCP Spurious Retransmission] 10554 → 80 [ACK] Seq=7001 Ack=1 Win=65...
10	0.128319	172.16.0.122	200.121.1.131	TCP	54	[TCP Dup ACK 2#3] [TCP ACKed unseen segment] 80 → 10554 [ACK] Seq=1 ...
11	0.154162	200.121.1.131	172.16.0.122	TCP	1454	[TCP Spurious Retransmission] 10554 → 80 [ACK] Seq=8401 Ack=1 Win=65...
12	0.154169	172.16.0.122	200.121.1.131	TCP	54	[TCP Dup ACK 2#4] [TCP ACKed unseen segment] 80 → 10554 [ACK] Seq=1 ...
13	0.179906	200.121.1.131	172.16.0.122	TCP	1454	[TCP Spurious Retransmission] 10554 → 80 [ACK] Seq=9801 Ack=1 Win=65...
14	0.179915	172.16.0.122	200.121.1.131	TCP	54	[TCP Dup ACK 2#5] 80 → 10554 [ACK] Seq=1 Ack=11201 Win=63000 Len=0
15	0.207145	200.121.1.131	172.16.0.122	TCP	1454	10554 → 80 [ACK] Seq=11201 Ack=1 Win=65535 Len=1400 [TCP segment of ...
16	0.207156	172.16.0.122	200.121.1.131	TCP	54	80 → 10554 [ACK] Seq=1 Ack=12601 Win=63000 Len=0
17	0.232621	200.121.1.131	172.16.0.122	TCP	1454	10554 → 80 [ACK] Seq=12601 Ack=1 Win=65535 Len=1400 [TCP segment of ...
18	0.232629	172.16.0.122	200.121.1.131	TCP	54	80 → 10554 [ACK] Seq=1 Ack=14001 Win=63000 Len=0
19	0.258365	200.121.1.131	172.16.0.122	TCP	1454	10554 → 80 [ACK] Seq=14001 Ack=1 Win=65535 Len=1400 [TCP segment of ...
20	0.258373	172.16.0.122	200.121.1.131	TCP	54	80 → 10554 [ACK] Seq=1 Ack=15401 Win=63000 Len=0

> Frame 15: 1454 bytes on wire (11632 bits), 1454 bytes captured (11632 bits)

> Ethernet II, Src: Vmware_c0:00:01 (00:50:56:c0:00:01), Dst: Vmware_42:12:13 (00:0c:29:42:12:13)

> Internet Protocol Version 4, Src: 200.121.1.131, Dst: 172.16.0.122

▼ Transmission Control Protocol, Src Port: 10554, Dst Port: 80, Seq: 11201, Ack: 1, Len: 1400

Source Port: 10554

Destination Port: 80

[Stream index: 0]

[TCP Segment Len: 1400]

Sequence number: 11201 (relative sequence number)

[Next sequence number: 12601 (relative sequence number)]

Acknowledgment number: 1 (relative ack number)

0101 = Header Length: 20 bytes (5)

0020 00 7a 29 3a 00 50 a7 5c 30 08 e2 e2 ee bf 50 10 .z).P.\ 0....P.

0030 ff ff bc 5e 00 00 42 4f 78 42 56 35 6a 45 52 52 ...^..B0 xBV5jERR

0040 71 5a 69 63 39 34 54 77 48 4c 71 46 51 34 78 35 qZic94Tw HLqFQ4x5

0050 61 62 46 30 77 55 6e 59 73 46 2b 67 6c 44 47 4c abF0wUnY sF+gIDGL

0060 33 56 75 35 65 61 33 4d 44 59 77 49 70 63 32 44 3Vu5ea3M DYwIpc2D

0070 78 4c 44 4d 74 38 6b 2f 75 42 68 38 6a 48 6d 30 xLDMt8k/ uBh8jHm0

0080 63 66 54 63 69 35 6a 77 77 4c 2f 56 4c 6f 6c 41 cFTci5jw wL/VLo1A

0090 57 4c 6c 35 63 43 79 4e 6d 63 36 52 70 58 57 7a wL15cCyN mc6RpXWz

Acknowledgment number (tcp.ack), 4 bytes

Packets: 3083 · Displayed: 3083 (100.0%)

Profile: Default

OSI Layers vs Common Attacks

Attack	OSI Layer
USB attack	Physical
ARP spoofing	Data Link
IP spoofing	Network
Port scanning	Transport
Session hijacking	Session
SSL stripping	Presentation
SQL Injection	Application

Mapping Hacking Tools to OSI Layers

Tool	OSI Layer
Nmap	Network / Transport
Wireshark	L2 – L7
Metasploit	Application
ARP Spoof	Data Link